

Ambitionz Rebirth

Relatório Industrial Consolidado — Codex × Claude

Cruzamento das duas auditorias independentes (o roadmap industrial do Codex e a auditoria de hardening do Claude), com cada achado **validado no código vivo**: o que converge (alta confiança), o que só um viu, o que já está resolvido e o que segue pendente — mais as melhorias que nenhum dos dois havia listado.

15 de junho de 2026 · engenharia + produção



1 · Sumário executivo

Duas auditorias independentes chegaram ao mesmo diagnóstico em quase todos os eixos industriais — **convergência independente é o sinal mais forte de que o diagnóstico está certo**. Onde Codex e Claude batem, tratamos como alta confiança; onde só um viu, sinalizamos a origem; e cada item foi conferido contra o código de hoje, porque parte do que auditorias antigas apontavam já foi corrigido (v100–v104).

O que o Codex agrega à minha auditoria: a disciplina de **testes adversariais de brecha viva** (Fase 0) e, sobretudo, o eixo de **publicação multiplataforma** (Web/Android/iOS) — que eu não havia coberto e confirmei ter pontos reais. **O que eu agrego** ao Codex: o **status verificado** de cada item (vários já feitos), os **números da regressão** de dívida, o veredito de que o **IDOR já está estruturalmente defendido**, e melhorias novas (wrapper WebView, rate-limit em memória). **Veredito conjunto**: sem P0 de correção aberto conhecido; o trabalho industrial é escala, dívida, dado honesto, blindagem de brecha e publicação.

2 · Matriz de convergência

Legenda: C = apontado pelo Codex · K = apontado pelo Claude · C+K = ambos (alta confiança).

Tema	Origem	Status no código (hoje)	Sev
Testes adversariais de brecha viva (IDOR, replay, economia)	C+K	Superfície defendida (ensure_match_access universal); falta bateria sistemática.	ALTO
Observabilidade + retenção D1/D7	C+K	Sentry SDK integrado (falta DSN/smoke em prod); funil ausente.	ALTO
Mobile player-first / reduzir ruído	C+K	P0.1 board vazio + jargão EVENT/cadeia ainda presentes.	ALTO
Modularização (js/css/app/persistence/engine)	C+K	Regrediu: arquivos cresceram +21% a +68%.	CRÍTICO
Escala / multi-worker	C+K	gunicorn -w 1 + estado em memória. Aberto.	CRÍTICO
Rate limit além de auth	C+K	Só auth; rotas de jogo/telemetria abertas.	MÉDIO
Backup/restore + load test + pixel-diff	C+K	Não feito.	MÉDIO
Balance honesto (simulador via dispatcher, 500+ partidas)	C+K	simulate_balance ainda não usa dispatcher.	ALTO
Deploy Android/iOS + PWA manifest	C	Confirmado: manifest 'one-card'/lang=en; ios/ ausente; appld divergente.	ALTO
Reconnect durável + abuso/report + season tooling	C+K	Não feito (já no roadmap AAA).	MÉDIO
WebView wrapper remoto (offline/loja/downtime)	K	capacitor server.url aponta Render; risco de loja e offline.	ALTO
Rate-limit/estado em memória não compartilhado	K	AUTH_RATE_LIMITS é dict em memória (igual MATCH_STORE).	MÉDIO
Os 2 P0 antigos (match_id, CSRF labs)	C+K	Resolvidos — confirmado pelos dois.	FEITO

3 · Plano consolidado por fases

Mantive a espinha do Codex (Fases 0–5, que é boa) e enriqueci cada fase com evidência de código e o status real de cada item.

Fase 0	Auditoria de brechas vivas
Objetivo. Provar que não há P0 escondido antes de qualquer beta maior. Codex propôs › Testes adversariais nas APIs mutantes; payloads abusivos; CSRF ausente/inválido; sessão trocada. › Autorização de match: ninguém lê estado/eventos/histórico de outro. › Economia: XP duplicado, booster repetido, daily, reset, admin grant. Relatório P0/P1/P2 só de exploráveis. Reforço / evidência (Claude) • IDOR já defendido estruturalmente: <code>ensure_match_access</code> em todas as mutantes (play-card 1615, attack 1675, evolve, next-turn, fusion) e leituras escopadas por <code>user_id</code>; <code>match_id</code> é <code>token_hex(16)</code> imprevisível. • Anti-injeção já é allowlist (<code>COMBAT_PAYLOAD_ALLOWED_FIELDS</code>). Logo: não é P0 aberto — é formalizar a bateria adversarial (2 jogadores concorrentes, replay duplicado, idempotência de economia), que a suíte ainda não cobre. Status verificado no código. Defesa presente; só <code>test_v74_guest_match_uniqueness</code> existe. Ação = suíte adversarial dedicada, não correção emergencial.	
Fase 1	Observabilidade real
Objetivo. Sem dado, 'melhorar' é achismo. Codex propôs › Sentry/GlitchTip em prod com smoke; eventos obrigatórios (<code>match_*</code>, <code>card_played</code>, <code>evolve</code>, <code>fusion</code>, <code>client_error</code>). › Medir first-match/tutorial completion, D1, D7, crash rate; dashboard de funil/abandono/erro por endpoint. › Só mexer forte em balance após 500+ partidas humanas. Reforço / evidência (Claude) • Sentry SDK já está integrado e gated por <code>SENTRY_DSN</code> (app.py:148) — falta confirmar DSN+smoke em produção. • Falta o logging estruturado (<code>request_id/user_id/match_id</code>) para correlacionar — sem isso o funil por turno não fecha. Status verificado no código. <code>sentry_sdk.init</code> presente; telemetria de eventos existe; dashboard D1/D7 por coorte real ainda não.	

Fase 2

Polimento mobile / player-first

Objetivo. Passar de 'tecnicamente ok' para 'premium nativo'.

Codex propôs

- › Redesenhar mulligan mobile (cartas maiores, menos truncamento); leitura clara de jogável/custo/ATK-GUARD/sickness/alvo.
- › Reduzir ruído do resultado (headline → dano → causa → detalhes ocultos).
- › Playwright sem force, desktop+mobile, partida inteira; 'player-eyes gate' (se humano não entende em 10s, reprova).

Reforço / evidência (Claude)

- Reconfirmei jogando hoje: P0.1 'jogador nunca tem board' ainda no feel casual (perdi 30→0 travado).
- Jargão de engine vaza na UI (EVENT-0/cadeia, rebirth.js:3106); 'Protegido no turno 1' renderiza em slot vazio (rebirth.js:2692).
- Crédito: reduced-motion já tratado no CSS (12 ocorrências) — a11y de movimento OK; falta a11y de teclado/ARIA/contraste.

Status verificado no código. Mobile passa nos asserts, mas os P0/P1 da auditoria olhos-de-jogador (11/jun) seguem visíveis. O 'gate' já é regra do repo.

Fase 3

Modularização de arquitetura

Objetivo. Onde o projeto vira industrial de verdade — zero mudança de gameplay.

Codex propôs

- › Quebrar rebirth.js (API/store/renderer/input/motion/tutorial), rebirth.css por domínio, app.py em blueprints, rebirth_persistence por repositório, rebirth_engine (combat/spells/traps/turn/rewards).

Reforço / evidência (Claude)

- Pontuado em 3 auditorias e regrediu: css 9,3k→15,6k (+68%), js 3,3k→4,7k (+45%), app 1,6k→2,5k (+61%), engine +34%, persistence +21%.
- resolve_turn (270L) e _apply_trap_effect (210L) seguem inteiros. A trava de contrato (test_rebirth_frontend_contract) + replay determinístico tornam o split seguro.

Status verificado no código. Nenhum split feito; dívida cresceu. É o item de maior alavanca técnica de médio prazo.

Fase 4

Release industrial

Objetivo. Pré-requisitos antes de beta pública.

Codex propôs

- › Legal review com evidência; backup/restore drill real; error tracking confirmado; GitHub closed-beta QA verde.
- › Load test 100–500 usuários (p95 por endpoint, erro/min); rate limit além de auth; pixel-diff/aprovação visual.

Reforço / evidência (Claude)

- Rate limit hoje cobre só auth (app.py:541); /start, /attack, /next-turn, /telemetry, /beacon abertos.
- AUTH_RATE_LIMITS é dict em memória — ao escalar, fura entre workers e zera no restart (mesmo vício do MATCH_STORE).

Status verificado no código. Gates de release já existem como contrato (rebirth_release_readiness/gate_evidence); falta a execução externa + load test.

Fase 5

Deploy Web / Android / iOS

Objetivo. Eixo que só o Codex cobriu — e tem pontos reais confirmados.

Codex propôs

- Web: corrigir copy do PWA manifest; Android: rebuild do AAB, screenshots/textos da Play Store, revisar appId.
- iOS: criar projeto ios/ via Capacitor, bundle id, signing, TestFlight; cookies/sessão/CSRF em WebView; checklist de loja do Rebirth atual.

Reforço / evidência (Claude)

- Confirmado: manifest.webmanifest diz 'A fast one-card monster duel' (linha 5) e lang='en' (21) — o jogo é 3 slots e a UI é pt-BR.
- ios/ não existe (só Android via mobile/AmbitionzAndroid). appId com.elementra.ambitiontcg com appName 'Ambitionz' (branding divergente).
- Risco novo (Claude): capacitor.config server.url aponta para o Render — o app de loja é um wrapper do site remoto.

Status verificado no código. Manifest defasado e ios/ ausente confirmados; deploy mobile não está pronto para loja.

4 · Backlog consolidado — pontuado e ainda não feito

União deduplicada das duas listas, com origem e severidade. (C=Codex, K=Claude, C+K=ambos.)

Item	Origem	Sev
Multi-worker readiness: tirar MATCH_STORE (e AUTH_RATE_LIMITS) da memória	C+K	CRÍTICO
Modularizar js/css/app/persistence/engine (resolve_turn, _apply_trap_effect)	C+K	CRÍTICO
Suíte adversarial: 2 jogadores concorrentes, replay duplicado, idempotência de economia	C+K	ALTO
Observabilidade: Sentry DSN+smoke em prod, logging estruturado, funil D1/D7 por coorte	C+K	ALTO
Balance honesto: simulate_balance via dispatcher + 500 partidas humanas + watchlist CI	C+K	ALTO
Arte própria 20→52→80% do catálogo	K	ALTO
P0.1 board vazio casual (2+ unidades, ~50% WR sem otimizar)	K	ALTO
Deploy mobile: rebuild AAB, projeto iOS real, WebView cookies/CSRF, assets de loja	C	ALTO
PWA manifest: corrigir copy 'one-card' e lang=en	C	MÉDIO
Rate limit em /start, /attack, /next-turn, /telemetry, /beacon	C+K	MÉDIO
Backup/restore drill + load test (p95) + multi-worker	C+K	MÉDIO
Pixel-diff / aprovação formal de baseline visual	C+K	MÉDIO
Reconnect durável (guest + autenticado) fora do processo	C+K	MÉDIO
Live config / versionamento / rollback de balance + season tooling	C+K	MÉDIO
Async ghost/replay como UI de produto + sistema de abuso/report antes de PvP	C+K	MÉDIO
Painel de resultado: hierarquia + esconder jargão EVENT/cadeia	K	MÉDIO
Tunar cartas (Scorchscale Imp 0.71, low-impact, dead-hand, earth_counter)	K	MÉDIO
'Protegido no turno 1' em slot vazio; reveal de booster; nomes truncados	K	BAIXO
Endurecer CSP para produção; documentar/destravar 5 testes skipped	K	BAIXO

5 · Melhorias adicionais (que nenhum dos dois listou)

- **Wrapper WebView remoto é frágil para loja.** capacitor.config aponta server.url ao Render — o app Android/iOS carrega o site remoto: sem modo offline, qualquer downtime do Render derruba o app publicado, e Apple/Google podem reprovar 'mero wrapper de site'. Decidir entre empacotar assets localmente (PWA offline) ou assumir o modelo remoto com fallback.
- **Rate limit e match state em memória não escalam juntos.** Ao ir para -w 2+, tanto MATCH_STORE quanto AUTH_RATE_LIMITS precisam de backend compartilhado, senão o limite de login fura (atacante distribui entre workers) e some no restart.
- **i18n formal.** Runtime é pt-BR mas o manifest declara lang=en e os contratos JSON são em inglês — sem camada de i18n, internacionalizar depois custa caro. Alinhar agora a intenção (pt-BR-first ou bilíngue).
- **Determinismo é um ativo subutilizado.** Já existe canonical_state_hash + replay; falta transformá-lo em produto (replay-share/spectator) e em ferramenta de suporte/anti-cheat — ROI alto sobre algo que já está pago.
- **Payload de runtime parcialmente otimizado.** v103 já stripa heuristic_vector (serializers:81), mas palette/silhouette seguem no contrato de carta — avaliar removê-los do estado de runtime também.
- **Crédito (não gastar esforço aqui).** Já resolvidos e confirmados: colisão de match_id, CSRF em labs, allowlist anti-injeção, código zumbi removido, CSP, compressão, reduced-motion, '100 vs 103'.

6 · Top 10 ações priorizadas (consolidado)

#	Ação	Origem	Por quê agora
1	Extrair MATCH_STORE + AUTH_RATE_LIMITS p/ backend compartilhado	C+K	Destrava multi-worker — teto de escala #1.
2	Suíte adversarial (IDOR/replay/economia) + relatório P0/P1/P2	C	Prova que não há P0 escondido antes de abrir beta.
3	simulate_balance via dispatcher real	C+K	Sem isso todo tuning de balance é cego.
4	Sentry DSN+smoke em prod + eventos + funil D1/D7	C+K	Sem dado, melhorar é achismo.
5	Quebrar resolve_turn / _apply_trap_effect	C+K	Reduz risco de regressão; destrava mecânica nova.
6	Revalidar P0.1 (board casual) com harness olhos-de-jogador	K	É a falha que ainda derruba a primeira sessão.
7	Rate limit em rotas de jogo + backup pré-migração	C+K	Brechas de produção baratas e de alto risco.
8	Corrigir PWA manifest (copy + lang) e appld	C	Defeito visível e barato; higiene de marca.
9	Projeto iOS real + WebView cookies/CSRF + assets de loja	C	Mobile não está pronto para publicação.
10	Pipeline de arte 20→52 cartas + pixel-diff de baseline	C+K	Maior risco de retenção + trava visual de QA.

7 · Portões de liberação

Portão	Inclui	Critério de saída
A — Beta ampliada	Top 1, 2, 6, 7	Sem P0 em suíte adversarial; worker-ready; board casual justo; deploy com backup.
B — Público controlado	Top 3, 4, 5, 10 + arte 50%	D1/D7 medidos; balance honesto; arquivos dentro do limite; observabilidade viva.
C — Lojas + Live/PvP	Top 8, 9 + reconnect + live config	iOS/Android publicáveis; manifest correto; match replayável; hotfix sem deploy.

Uma linha: Codex e Claude concordam no essencial — os bugs que quebravam partida já foram fechados; o industrial agora é **escala, dívida, dado honesto, blindagem de brecha e publicação multiplataforma**, com todos os achados verificados contra o código vivo.